EUROGRID FINANCE - DORA & NIS2 REGÜLASYON UYUM DENETİM RAPORU

Denetlenen Kurum: EuroGrid Finance

Denetim Alanı: Siber Dayanıklılık ve Regülasyon Uyumluluğu (DORA & NIS2)

Denetim Tarihi: Haziran 2026

Denetçi: Necdet Emre Bayraktar (Bilgi Sistemleri Denetçisi Adayı)

1. Yönetici Özeti

Bu rapor, 12 Avrupa ülkesinde faaliyet gösteren, 6.200 çalışanı bulunan ve 2,8 milyon müşteriye hizmet veren EuroGrid Finance'ın teknolojik altyapısının, süreçlerinin ve üçüncü taraf ilişkilerinin DORA (Digital Operational Resilience Act) ve NIS2 direktiflerine uyum durumunu değerlendirmek amacıyla hazırlanmıştır. Şirket yönetimi; DORA ve NIS2 gereksinimlerinin tamamının karşılandığı, kritik tedarikçilerin etkin yönetildiği, siber olayların zamanında raporlandığı ve iş sürekliliği süreçlerinin test edildiği yönünde denetim ekibine güvence vermiştir.

Yapılan incelemeler sonucunda, kurumun aktif bir Güvenlik Operasyonları Merkezi (SOC) yapısına sahip olduğu, teknolojik yatırımlarının bulunduğu ve güvenlik farkındalığına yönelik adımlar atıldığı görülmüştür. Ancak kanıta dayalı bağımsız denetim sonucunda, yönetim beyanları ile sahadaki veriler arasında önemli tutarsızlıklar tespit edilmiştir. Yönetim Kuruluna "açık bulgu bulunmadığı" raporlanırken tarama araçlarında **127 kritik ve 612 yüksek** seviyeli açık zafiyet bulunmaktadır. Core Banking, SWIFT, Mobile Banking ve ödeme sistemleri kritik fonksiyon envanterinde yer almamakta, 194 tedarikçinin yalnızca 34'üne risk değerlendirmesi yapılmıştır.

Kurumun DORA ve NIS2 denetimlerinden başarıyla geçebilmesi için; operasyonel güvenlik görünürlüğünün Yönetim Kuruluna şeffaf şekilde aktarılması, envanter kapsamının genişletilmesi, olay müdahale süreçlerinin regülatif sürelere (24/72 saat) hizalanması ve üçüncü taraf risk yönetiminin güncel standartlara kavuşturulması öncelikli gelişim alanları olarak tespit edilmiştir.

2. Denetim Kapsamı

Bu denetim, EuroGrid Finance'ın kritik sistemleri (Core Banking Platform, Mobile Banking, Customer Portal, SWIFT Infrastructure, Microsoft 365, AWS, Azure ve Payment Gateway) üzerinde aşağıdaki regülasyon başlıklarını kapsamaktadır:

- **DORA:** ICT Risk Yönetimi (Chapter II), ICT Olay Yönetimi (Chapter III), Dijital Operasyonel Dayanıklılık Testleri (Chapter IV), Üçüncü Taraf ICT Risk Yönetimi (Chapter V), Bilgi Paylaşımı (Chapter VI).
- **NIS2:** Yönetişim, Risk Yönetimi, Olay Bildirimi, Tedarik Zinciri Güvenliği, İş Sürekliliği, Zafiyet Yönetimi ve Siber Hijyen.

3. Yapılan Testler

Yönetim beyanlarına güvenilmeden, kurumun sağladığı dokümanlar ve operasyonel veriler birbiriyle karşılaştırılmıştır:

- Yönetim Kurulu siber güvenlik raporu (Board_Cyber_Reports.pdf, Mayıs 2024) ile SOC aylık raporu (Mart 2026) ve zafiyet tarama raporunun (Qualys VMDR, 03 Mart 2025) karşılaştırılması.
- ICT Varlık Envanteri, Kritik Fonksiyon Envanteri ve ICT Risk Kütüğünün (ICT_Risk_Register.xlsx) BT operasyon verileriyle karşılaştırılması.
- Güvenlik Olay Kütüğü (Incident_Register.xlsx) ve olay bildirim prosedürünün DORA bildirim süreleriyle karşılaştırılması.
- Tedarikçi Kütüğü (Third_Party_Register.xlsx), Kritik ICT Sağlayıcı Değerlendirmesi, BCP, DR testi ve masa başı tatbikatı kanıtlarının incelenmesi.
- CEO, CIO, CISO ve Vendor Manager ile yapılan görüşmelerdeki beyanların kanıtlarla doğrulanması.

4. Tespit Edilen Bulgular

4.1 Yönetişim ve Yönetim Kurulu Gözetimi (Governance & Oversight - NIS2 / DORA)

Bulgu 4.1.1 - Yönetim Kurulu Raporlamaları: Yönetim Kuruluna sunulan son siber güvenlik raporu (15 Mayıs 2024) kurumun güvenlik duruşunu "stabil ve kabul edilebilir" olarak tanımlamakta; 0 kritik zafiyet, yalnızca 3 olay ve %94 yama uyumluluğu raporlamaktadır. Ancak zafiyet tarama aracında 127 kritik ve 612 yüksek açıklık bulunmakta, yama uyumluluk oranı %36,6 (530 sunucunun 336'sı eksik yamalı) olarak ölçülmektedir. Sonraki raporun Q3 2024'te sunulacağı belirtilmiş olmasına rağmen Mayıs 2024'ten sonra yeni bir Kurul raporu bulunmamaktadır.

- **Risk Seviyesi: Critical** (DORA "Yönetim Kurulu Sorumluluğu" ihlali)
- **Root Cause Analysis (RCA):** SOC ve zafiyet tarama araçlarının ürettiği operasyonel verilerin Kurul raporlarına filtrelenmeden aktarılmasını sağlayan bir süreç ve bağımsız doğrulama fonksiyonunun olmaması.
- **Öneri:** SOC raporları ile Kurul raporları arasındaki veri akışı otomatikleştirilmeli, raporlar bağımsız bir IT GRC fonksiyonu tarafından doğrulanmalı ve gerçek zamanlı olay ve açıklık bilgisi üst yönetime şeffaf şekilde raporlanmalıdır.

4.2 ICT Risk Yönetimi ve Varlık Envanteri (ICT Risk Management - DORA Chapter II)

Bulgu 4.2.1 - Envanter Kapsamı: ICT Varlık Envanterinde toplam 284 varlık kayıtlıdır. Ancak BT operasyon verilerine göre kurumda 970 sunucu, 320 network cihazı, 580 SaaS uygulaması, 120 AWS hesabı ve 35 Azure aboneliği bulunmakta olup AWS ve Azure kaynakları envanterde görünmemektedir. Kritik Fonksiyon Envanterinde yalnızca E-mail, HR Portal ve Intranet

listelenmiş; SWIFT, Core Banking, Mobile Banking ve Payment Processing kayıtlı değildir. CIO'nun "kritik sistemlerin tamamı envanter altında" beyanı kanıtlarla desteklenmemektedir.

- **Risk Seviyesi: Critical**
- **Root Cause Analysis (RCA):** Varlık ve kritik fonksiyon envanterinin BT operasyonları ve bulut ortamlarıyla entegre olmayan manuel yöntemlerle yürütülmesi.
- **Öneri:** Envanter; SWIFT altyapısı, Core Banking platformu, Mobil/Ödeme sistemleri ve tüm bulut hesaplarını (AWS/Azure) kapsayacak şekilde güncellenmeli ve otomatik keşif araçlarıyla güncel tutulmalıdır.

Bulgu 4.2.2 - Risk Değerlendirme Döngüsü: ICT Risk Kütüğünde yalnızca 14 risk bulunmakta olup kütük en son 12 Ocak 2023 tarihinde güncellenmiştir. Bulut Konsantrasyon Riski, Tedarik Zinciri Saldırısı, Yapay Zeka Riski, Üçüncü Taraf Kesintisi ve Jeopolitik Tehditler değerlendirilmemiştir. Ayrıca "İçeriden Gelen Tehditler (Insider Threat)" gibi düşük olasılıklı ancak yüksek etkili (High Impact) riskler "Kabul Etme (Accept)" stratejisiyle ele alınmıştır.

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** Risk yönetiminin yaşayan bir süreç olmaktan çıkması ve güncel tehdit bilgisinin (SOC'un raporladığı Credential Theft, MFA Fatigue, Cloud Abuse vb.) risk kütüğüne yansıtılmaması.
- **Öneri:** Risk kütüğü yıllık periyotlarla ve kurumsal risk iştahına uygun olarak yenilenmeli; yüksek etkili riskler için "Kabul Etme" yerine "Azaltma (Mitigate)" veya sigorta yoluyla "Transfer Etme" stratejileri kurgulanmalıdır.

4.3 ICT Olay Yönetimi ve Bildirimi (ICT Incident Management - DORA Chapter III / NIS2)

Bulgu 4.3.1 - Olay Kayıt ve Sınıflandırma: SOC raporlarında tespit yeteneğinin aktif olarak çalıştığı görülmüştür. Mart 2026 SOC raporunda 43 Malware, 71 Phishing, 112 Brute Force, 12 Privilege Escalation, 55 Şüpheli PowerShell, 4 Veri Sızdırma (Data Exfiltration) ve 9 DDoS olayı doğrulanmış, 306 yüksek önem dereceli olay raporlanmıştır. Buna karşın resmi Güvenlik Olay Kütüğünde 2025 yılı için yalnızca 4 olay kayıtlıdır ve hiçbirinde regülatör bildirimi gerekli görülmemiştir. CISO'nun "olaylarımız raporlanıyor" beyanı SOC kayıtlarıyla çelişmektedir.

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** SOC ile Olay Müdahale (Incident Response) ve risk yönetimi ekipleri arasında eskalasyon akışının ve standart olay sınıflandırma (severity classification) kriterlerinin olmaması.

Bulgu 4.3.2 - Regülatif Bildirim Süreçleri: Olay bildirim prosedüründe (Incident_Reporting.docx) bildirim süresi "olaylar uygun zamanda raporlanır" gibi genel bir ifadeyle tanımlanmıştır. DORA ve NIS2 ise majör olaylarda yetkili kurumlara ilk 24 saat içinde ilk bildirim ve 72 saat içinde detaylı rapor yapılmasını zorunlu kılmaktadır.

- **Risk Seviyesi: Critical** (Regülatör yaptırımı riski)

- **Root Cause Analysis (RCA):** Kurum politikalarının DORA/NIS2 yürürlüğe girdikten sonra regülasyon gereksinimlerine göre güncellenmemesi.
- **Öneri:** Yüksek önem dereceli olayların Olay Müdahale ekibine eksiksiz aktarımını sağlayacak eskalasyon akışları güçlendirilmeli ve DORA'nın 24/72 saatlik resmi bildirim zorunlulukları kurum politikalarına entegre edilmelidir.

4.4 Zafiyet Yönetimi ve Siber Hijyen (Vulnerability Management & Cyber Hygiene - NIS2)

Bulgu 4.4.1 - Zafiyet Tarama Güncelliği: Son zafiyet taraması 03 Mart 2025 tarihinde (denetim tarihinden 15 ay önce) yapılmıştır. Taramada 127 Critical, 612 High ve 1.490 Medium olmak üzere toplam 5.250 açıklık bulunmakta ve aksiyon durumu "Open" olarak görünmektedir. Kurula raporlanan %94 yama uyumluluğu ile tarama aracının ölçtüğü %36,6 arasında ciddi bir fark vardır.

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** Zafiyet taramasının sürekli değil dönemsel ve düzensiz yapılması; yama uyumluluk metriklerinin tek ve doğrulanmış bir kaynaktan üretilmemesi.

Bulgu 4.4.2 - Kritik Sistem Yamaları: Kurumun can damarı olan sistemlerde uzun süredir kapatılmamış kritik zafiyetler bulunmaktadır: SWIFT-APP01 (247 gün), PAY-GW02 (183 gün), COREBANK01 (161 gün) ve M365-Connector (133 gün). Ayrıca IAM projesi "Red" statüsünde olup 11 ay gecikmiştir.

- **Risk Seviyesi: Critical**
- **Root Cause Analysis (RCA):** Kaynak yetersizliği ve bütçe aşımı (%38) nedeniyle güvenlik projelerinin ertelenmesi; finansal işlem yapan sistemler için acil yama (immediate remediation) sürecinin bulunmaması.
- **Öneri:** Zafiyet taramaları sürekli hale getirilmeli (continuous monitoring), internete açık veya finansal işlem yapan sistemler (SWIFT, Core Banking, Payment Gateway) için acil yama süreci işletilmelidir. IAM projesine ek kaynak ayrılarak Kaba Kuvvet (Brute Force) risklerine karşı sistemler sıkılaştırılmalıdır.

4.5 İş Sürekliliği, Felaket Kurtarma ve Dayanıklılık (Business Continuity & Digital Resilience - DORA Chapter IV)

Bulgu 4.5.1 - Test ve Otomasyon: İş Sürekliliği Planı (BCP) en son 2022 yılında güncellenmiş ve hiç test edilmemiştir. RTO belirlenmiş olmasına rağmen RPO belirlenmemiştir. Operasyon Müdürü "her yıl test ediyoruz" beyanında bulunmasına rağmen DR testine ait kanıt bulunamamıştır. Son masa başı tatbikatı (Tabletop Exercise) 2023 yılında yalnızca BT ekibinin katılımıyla yapılmış, Yönetim Kurulu katılmamıştır. DR Otomasyon projesi (€0,9M) bütçe ve kaynak sorunları nedeniyle "Red" statüsündedir.

- **Risk Seviyesi: Critical**
- **Root Cause Analysis (RCA):** İş sürekliliği sürecinin kanıta dayalı test döngüsü yerine kağıt üzerinde yürütülmesi ve DR projelerine üst yönetim desteği verilmemesi.

- **Öneri:** DR otomasyon projesine gerekli kaynak sağlanmalı, BCP/DR tatbikatları Yönetim Kurulu üyelerini de kapsayacak senaryolarla yıllık olarak yapılmalı ve sonuçları resmi olarak kayıt altına alınmalıdır.

4.6 Üçüncü Taraf ICT Risk Yönetimi (ICT Third-Party Risk Management - DORA Chapter V / NIS2)

Bulgu 4.6.1 - Tedarikçi Risk Değerlendirmeleri: Toplam 194 tedarikçinin yalnızca 34'üne risk değerlendirmesi yapılmış, 52'sinin sözleşmesinde güvenlik maddesi bulunmakta ve 160 tedarikçi hiç gözden geçirilmemiştir. Kritik ICT sağlayıcılarının (AWS, Microsoft, Cloudflare, CrowdStrike, Okta) değerlendirmesi en son Mart 2022'de yapılmış, alt yüklenici (4th party) değerlendirmesi bulunmamaktadır. Vendor Manager'ın "tedarikçi değerlendirmeleri düzenli yapılmaktadır" beyanı kanıtlarla desteklenmemektedir.

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** Üçüncü taraf risk yönetimi (TPRM) sürecinin işletilmemesi; Satınalma/Hukuk ile Bilgi Güvenliği arasında süreç entegrasyonunun olmaması.

Bulgu 4.6.2 - Konsantrasyon Riski ve Çıkış Stratejileri: DORA'nın en çok önem verdiği başlıklardan biri olan "Çıkış Stratejisi (Exit Plan)" 194 tedarikçinin yalnızca 4'ünde bulunmaktadır. Kritik sağlayıcılar için Konsantrasyon Riski Analizi yapılmamış ve dayanıklılık testi bulunmamaktadır.

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** Belirli bulut sağlayıcılarına olan bağımlılığın bir iş riski olarak değerlendirilmemesi.
- **Öneri:** Tüm tedarikçiler risk tabanlı bir sınıflandırmadan geçirilmeli, sözleşmelere siber güvenlik ve denetim maddeleri (Security Clauses) eklenmeli ve kritik bulut sağlayıcıları için hizmet kesintisinde verilerin nasıl taşınacağını belirleyen Çıkış Planları teknik ve süreçsel olarak belgelenmelidir.

5. Risk Değerlendirmesi ve Regülasyon Uyum Haritası

Alan	Regülasyon	Risk Seviyesi	Bulgu ve Olası Etki
Yönetişim ve Kurul Gözetimi	NIS2 Yönetişim / DORA Chapter II	**Critical**	Kurul gerçek risk tablosunu görmüyor; yönetim sorumluluğu yerine getirilemiyor (4.1.1).
Varlık Envanteri	DORA Chapter II	**Critical**	Core Banking, SWIFT ve bulut kaynakları envanter dışında; korunamayan varlıklar (4.2.1).
ICT Risk Kütüğü	DORA Chapter II / NIS2 Risk Yönetimi	**High**	2023'ten beri güncellenmeyen 14 risk; güncel tehditler değerlendirilmiyor (4.2.2).

Alan	Regülasyon	Risk Seviyesi	Bulgu ve Olası Etki
Olay Kayıt ve Bildirim	DORA Chapter III / NIS2 Olay Bildirimi	**Critical**	SOC olaylarının kütüğe yansımaması ve 24/72 saat bildirim süresi tanımsızlığı regülatör yaptırımına yol açabilir (4.3.1, 4.3.2).
Zafiyet ve Yama Yönetimi	NIS2 Zafiyet Yönetimi / Siber Hijyen	**Critical**	SWIFT ve ödeme sistemlerindeki 133-247 günlük kritik açıklıklar finansal saldırı riskidir (4.4.1, 4.4.2).
İş Sürekliliği ve DR	DORA Chapter IV / NIS2 İş Sürekliliği	**Critical**	Test edilmemiş BCP ve tanımsız RPO, kesintide veri kaybına ve hizmet duruşuna neden olur (4.5.1).
Üçüncü Taraf Riski	DORA Chapter V / NIS2 Tedarik Zinciri	**High**	160 incelenmemiş tedarikçi ve 4 çıkış planı; konsantrasyon ve tedarik zinciri saldırısı riski (4.6.1, 4.6.2).

6. Sonuç ve Regülatör Denetimi Öncesi Hazırlık Planı

Sayın EuroGrid Finance Yönetim Kurulu ve Üst Yönetimi,

EuroGrid Finance, Avrupa genelinde sunduğu kritik finansal hizmetler ve teknolojik altyapısı ile büyük bir potansiyele sahiptir. Kurumun teknoloji güvenliğine bütçe ayırdığı ve SOC gibi ileri düzey savunma mekanizmaları kurduğu görülmektedir. Ancak teknik sahadaki bu potansiyelin kurumsal yönetişim ile entegre edilememesi, DORA ve NIS2'nin "Yönetim Kurulu Sorumluluğu" ilkeleriyle örtüşmemektedir. Olası bir resmi regülatör denetiminden başarıyla geçilmesi için aşağıdaki 3 Aşamalı Acil Eylem Planının hayata geçirilmesi kuvvetle önerilir:

1. **Yönetişim Kalibrasyonu (Acil - İlk 30 Gün):**
    - Yönetim Kurulu raporları ile SOC/teknik ekiplerin verileri arasındaki farklılıkların giderilmesi.
    - Yüksek seviyeli güvenlik olaylarının (veri sızdırma teşebbüsleri vb.) DORA bildirim sürelerine (24-72 saat) uygun olarak regülatörlere raporlanma sürecinin resmi bir politikaya bağlanması.
2. **Kritik Sistemlerin Hijyeni (Kısa Vade - İlk 90 Gün):**
    - Core Banking, SWIFT ve Payment sistemlerinin acilen envantere dahil edilmesi ve bekleyen kritik (Critical/High) yamaların uygulanması.
    - Kaynak yetersizliği nedeniyle "Red" statüye düşen IAM ve DR otomasyon projelerinin üst yönetim inisiyatifiyle yeniden canlandırılması.

3. **Üçüncü Taraf ve Süreklilik Güvencesi (Orta Vade - İlk 180 Gün):**
    - Bulut sağlayıcıları başta olmak üzere tüm kritik tedarikçiler için Konsantrasyon Riski analizlerinin ve Çıkış Stratejilerinin (Exit Plan) oluşturulması.
    - İş Sürekliliği Planlarının, üçüncü taraf sağlayıcıları ve Yönetim Kurulu üyelerini de kapsayan Masa Başı Tatbikatları ile her yıl kanıta dayalı olarak test edilmesi.